

ClinicBridge

Plataforma de migração segura de dados administrativos para clínicas pequenas

Documentação Inicial do Projeto

Autor	Marco
E-mail	canaldosbons@gmail.com
Versão	1.0
Data	Maio de 2026

Documento construído a partir da análise dos materiais da pasta "Ciber" (Software Seguro, Resposta a Incidentes), aplicando STRIDE, OWASP, CIAA, MVC + DAO e princípios de LGPD.

Sumário

- 1. Introdução
- 2. Justificativa
- 3. Objetivos
- 4. Descrição do sistema
- 5. Arquitetura MVC + DAO
- 6. Banco de dados
- 7. Fluxo principal do sistema
- 8. Segurança
- 9. Modelagem de ameaças (STRIDE)
- 10. Backlog por sprints
- 11. Modelo de monetização
- 12. Próximos passos
- 13. Conclusão
- 14. Referências e conceitos utilizados (pasta Ciber)

1. Introdução

O ClinicBridge é um projeto de SaaS direcionado a clínicas pequenas e profissionais de saúde autônomos que precisam migrar dados de sistemas antigos para novas ferramentas. O foco da primeira versão é em dados administrativos — pacientes, contatos, agenda, convênio — evitando dados clínicos sensíveis para reduzir risco regulatório e manter o escopo controlado.

O produto nasce com segurança aplicada desde o desenho, usando como base conceitos de modelagem de ameaças, padrões de projeto e codificação segura discutidos ao longo das aulas de Software Seguro e Resposta a Incidentes.

2. Justificativa

Migrar dados entre sistemas é uma necessidade frequente em clínicas. Hoje esse processo costuma ser feito manualmente, por alguém da secretaria, copiando informação entre planilhas. É lento, propenso a erro e expõe dados pessoais em arquivos sem controle de acesso.

Uma ferramenta especializada que cuide desse processo de forma segura, auditável e simples de usar tem espaço claro de mercado, especialmente entre clínicas pequenas que não têm equipe de TI dedicada.

3. Objetivos

3.1 Objetivo geral

Oferecer uma plataforma web que ajude clínicas pequenas a migrar, limpar e exportar dados administrativos de forma segura, auditável e em conformidade com a LGPD.

3.2 Objetivos específicos

- Aceitar upload de arquivos CSV e XLSX exportados de sistemas antigos.
- Detectar colunas comuns e sugerir mapeamento automático.
- Validar campos sensíveis (telefone, e-mail, CPF, data de nascimento).
- Identificar duplicados e dados incompletos.
- Permitir revisão e correção antes da exportação final.
- Gerar arquivos limpos em CSV e XLSX prontos para outro sistema.
- Manter logs de auditoria de todas as ações relevantes.
- Garantir isolamento de dados por clínica (multi-tenant).
- Atender requisitos de consentimento, exportação e exclusão (LGPD).

4. Descrição do sistema

O sistema é uma aplicação web multi-tenant. O usuário cria a conta, cadastra sua clínica, sobe um arquivo exportado do sistema antigo e passa por um fluxo guiado de mapeamento de colunas, validação, revisão e exportação. Ao final, recebe arquivos limpos em CSV e XLSX, além de um relatório de migração em PDF.

Internamente, o backend processa os arquivos em fila assíncrona para lidar com volumes maiores sem travar a aplicação. Todas as ações sensíveis ficam registradas em uma trilha de auditoria.

4.1 Escopo do MVP

- Autenticação e cadastro de clínica.
- Upload, parse e preview de CSV/XLSX.
- Mapeamento de colunas com sugestão automática.
- Validação, detecção de duplicados e revisão.
- Exportação em CSV, XLSX e relatório PDF.
- Logs de auditoria e painel básico.

4.2 Fora do escopo na primeira versão

- Prontuário clínico completo.
- Diagnóstico, prescrição, laudos e exames.
- Telemedicina e assinatura digital de receitas.
- Faturamento e integração com convênios.
- Aplicativo móvel.

5. Arquitetura MVC + DAO

A arquitetura segue o padrão MVC (Model, View, Controller) com DAO (Data Access Object) isolando o acesso ao banco. Adicionamos uma camada de Service para regras de negócio mais pesadas, mantendo o Controller curto e o DAO restrito a queries parametrizadas.

5.1 Papel de cada camada

- **Model:** entidades de domínio (Usuario, Clinica, Paciente, ArquivoImportacao, Migracao, ErroImportacao, LogAuditoria).
- **View:** telas React do frontend (Login, Dashboard, Upload, Preview, Revisão, Exportação).
- **Controller:** handlers HTTP que validam input, autenticam, autorizam e coordenam o fluxo.
- **Service:** regras de negócio (parse, normalização de telefone, detecção de duplicados, geração de relatório).
- **DAO:** ponto único de acesso ao banco, com queries parametrizadas e filtro obrigatório por clinica_id.

5.2 Comunicação entre camadas

View → Controller → Service → DAO → Banco. A View nunca executa SQL. O Controller nunca decide regra de negócio crítica sem passar pelo Service. O DAO nunca toma decisão de negócio.

5.3 Vantagens dessa escolha

- Facilita revisão de segurança (SQL concentrado em poucos arquivos).
- Permite testar regras de negócio sem subir o banco.
- Diminui o risco de SQL Injection (parametrização padronizada).
- Suporta auditoria via middleware sem alterar Controllers.

5.4 Estrutura de pastas sugerida

```
/backend/src/{config, models, dao, services, controllers, routes, middlewares, utils, jobs}  
/backend/migrations /backend/tests  
/frontend/src/{views, components, services, hooks, utils}  
/docs docker-compose.yml
```

6. Banco de dados

Banco escolhido: PostgreSQL 15+. Tipos JSONB para mapeamento de colunas, suporte a UUID, integridade referencial e extensões úteis como pgcrypto.

6.1 Tabelas principais

Tabela	Função
users	Usuários do sistema (dono, secretaria, admin).
clinics	Clínicas; cada usuário pertence a uma.
patients	Dados administrativos dos pacientes da clínica.
import_files	Metadados dos arquivos enviados.
migrations	Cada migração com mapeamento e contadores.
migration_errors	Erros e avisos por linha do arquivo.
audit_logs	Trilha imutável de eventos sensíveis.

6.2 Relacionamentos principais

- Um usuário pertence a uma clínica (clinica_id em users).
- Uma clínica tem N pacientes, N arquivos e N migrações.
- Cada arquivo gera uma migração; cada migração gera N erros.
- Cada paciente pode apontar para a migração que o originou.
- audit_logs referencia clínica e usuário, mas só permite INSERT.
- ON DELETE CASCADE em recursos sensíveis para atender exclusão (LGPD), preservando apenas os logs de auditoria.

7. Fluxo principal do sistema

7.1 Fluxo do usuário

- 1. Usuário cria conta com e-mail e senha forte.
- 2. Cadastra a clínica e aceita Termos e Política de Privacidade.
- 3. Sobe o arquivo exportado do sistema antigo (CSV/XLSX).
- 4. Vê um preview do conteúdo e confirma/ajusta o mapeamento de colunas.
- 5. Sistema valida campos, detecta duplicados e dados incompletos.
- 6. Usuário revisa e corrige o que faltar.
- 7. Exporta CSV/XLSX limpo e baixa relatório PDF.
- 8. Cada passo sensível é registrado em audit_logs.

7.2 Fluxo técnico (backend)

- Autenticação por sessão/token com middleware obrigatório.
- Upload via multipart com validação de tipo, MIME real, tamanho e hash.
- Arquivo armazenado em S3-compatível, nome interno em UUID.
- Job enfileirado no Redis/BullMQ para parse em streaming.
- Worker valida linhas, grava erros e atualiza contadores da migração.
- Frontend acompanha progresso por polling/SSE.
- Exportação gera CSV + XLSX + PDF; download por URL assinada curta.
- Middleware auditLogger registra ação em audit_logs.

8. Segurança

A seção de segurança parte do princípio de CIAA (Confidencialidade, Integridade, Disponibilidade, Autenticidade), reforçado por princípios do OWASP (atenção a A06 — Insecure Design) e pelo ciclo de Resposta a Incidentes do NIST.

8.1 Autenticação e senhas

- Hash forte com argon2id (alternativa bcrypt com cost ≥ 12).
- Política mínima de 10 caracteres com letra e número.
- Bloqueio temporário após 5 falhas seguidas.
- Login (sucesso e falha) registrado em audit_logs.
- Recuperação de senha via token único por e-mail (sem perguntas/respostas).

8.2 Autorização e multi-tenant

- Verificação dupla: papel do usuário (RBAC) e clinica_id.
- Middleware requireAuth + requireSameClinic em rotas sensíveis.
- DAO recebe clinica_id como parâmetro obrigatório em queries.
- Teste automatizado: cross-tenant retorna 403.

8.3 Proteção contra ataques clássicos

- SQL Injection: 100% das queries parametrizadas via ORM.
- XSS: escape padrão do React; CSP restritivo; sem dangerouslySetInnerHTML.
- CSRF: tokens em rotas que mudam estado; cookies SameSite=Lax.
- Clickjacking: X-Frame-Options: DENY.
- Sniffing: HSTS e TLS 1.2+ obrigatórios.

8.4 Upload seguro

- Allowlist de extensões: .csv e .xlsx.
- Verificação de MIME real (não confiar no nome).
- Limite de 20 MB e timeout de 5 minutos.
- Nome interno em UUID; hash SHA-256 calculado e armazenado.
- Storage privado; download via URL assinada com expiração de 10 minutos.

8.5 Criptografia

- TLS em trânsito (HTTPS obrigatório).
- Criptografia em repouso para arquivos no storage.
- Senhas com hash argon2id.
- Em médio prazo: criptografia em coluna para CPF.

8.6 Auditoria, backup e operação

- audit_logs apenas append; sem UPDATE/DELETE.
- Timestamp confiável (NTP) em todos os servidores.
- Backup diário criptografado, retenção mínima de 30 dias.

- Restore testado pelo menos uma vez por mês.
- Princípio do menor privilégio nas credenciais do banco.
- Rate limit em login e upload.

8.7 LGPD

- Termos e Política aceitos antes do uso, com versão e data registrados.
- Contrato de tratamento de dados (operador) com a clínica.
- Exportação autoatendida de todos os dados.
- Exclusão autoatendida com confirmação por e-mail.
- DPO definido, com canal público de contato.
- Minimização: sem dado clínico no MVP.
- Retenção limitada: arquivos brutos apagados em até 30 dias após migração.

8.8 Resposta a incidentes (NIST SP 800-61)

- Preparação: playbook escrito, contatos, logs, NTP, retenção.
- Detecção: alertas para falhas em massa de login, picos de upload, 5xx.
- Contenção: bloqueio de IP, rotação de tokens, isolamento de worker.
- Erradicação: patch da causa raiz, troca de credenciais.
- Recuperação: restore de backup quando necessário.
- Lições aprendidas: post-mortem documentado.

9. Modelagem de ameaças (STRIDE)

Aplicação simplificada do método STRIDE descrito no material de Software Seguro. Para cada categoria, descrição, impacto e mitigação no contexto do ClinicBridge.

Categoria	Descrição / Risco	Mitigação
Spoofing	Atacante se passa por usuário ou clínica.	argon2, rate limit, MFA opcional, tokens curtos, log de tentativas.
Tampering	Alteração indevida de dados em trânsito ou em repouso.	HTTPS, validação no servidor, hash SHA-256 de upload, tráfego assinado.
Repudiation	Usuário nega ter feito uma ação destrutiva.	audit_logs imutáveis, request_id, NTP, confirmação por e-mail.
Information Disclosure	Vazamento de dados sensíveis ou enumeração de dados.	RL assinadas, mensagens de erro neutras, logs sem PII.
Denial of Service	Brute force, arquivos enormes, abuso de endpoints.	Rate limit, limite de tamanho, fila com timeout, captcha após tentativas.
Elevation of Privilege	Usuário comum acessa rotas/dados administrativos.	RBAC e autenticação. Controller e no DAO; testes de cross-tenant.

10. Backlog por sprints

Sprint 1 — MVP base (2 semanas)

- Cadastro de usuário com senha forte.
- Login com sessão/token.
- Cadastro de clínica com aceite de termos.
- Upload de CSV/XLSX com validação básica.
- Parse e preview das primeiras linhas.
- Tela de mapeamento de colunas.

Sprint 2 — Migração (2 semanas)

- Normalização de telefone, e-mail e CPF.
- Detecção de duplicados por CPF e por nome+telefone.
- Tela de revisão com corrigir/ignorar/mesclar.
- Exportação limpa em CSV e XLSX.
- Relatório PDF de migração.

Sprint 3 — Segurança e auditoria (2 semanas)

- audit_logs cobrindo ações sensíveis.
- Controle multi-tenant validado por testes.
- Hardening de upload (MIME real, hash, tamanho).
- Backup diário automatizado com teste de restore.
- Rate limit em login e upload.
- Cabeçalhos de segurança (CSP, HSTS, etc.).

Sprint 4 — Comercial (2 semanas)

- Landing page com CTA.
- Formulário de lead com double opt-in.
- Plano pago com Stripe ou Pagar.me.
- Painel administrativo simples.
- Página de exclusão/exportação de dados (LGPD).

Sprint 5 (opcional) — Refino pós-MVP

- Convite de secretária com permissão restrita.
- Integração com WhatsApp Business (sem dado clínico).
- Modo dry run para parceiros de migração.
- Importação direta dos sistemas mais comuns do mercado.

11. Modelo de monetização

- **Plano avulso:** valor único por migração, por volume de pacientes (R\$ 199 até 500; R\$ 399 até 2.000; R\$ 799 acima).
- **Plano recorrente mensal:** mantém histórico, novas migrações, relatórios e backup criptografado.
- **Plano de parceria:** consultores e revendedores que atendem várias clínicas usam a plataforma e pagam por cliente atendido.

Para o lançamento, o foco é validar o avulso, que tem ciclo de venda curto e responde diretamente à dor pontual do cliente.

12. Próximos passos para implementação

- Validar a dor com 5 a 10 clínicas pequenas (entrevistas curtas).
- Definir identidade visual mínima e nome de domínio.
- Setup do repositório, CI e templates de PR.
- Executar as quatro sprints do MVP em cerca de 8 a 10 semanas.
- Soft launch com 3 a 5 clientes-piloto e desconto.
- Habilitar pagamento avulso e medir conversão.
- Medir tempo médio de migração, NPS e ocorrência de incidentes.

Critérios para considerar o MVP validado

- Pelo menos 5 migrações pagas concluídas.
- NPS médio igual ou maior que 7.
- Zero incidentes de segurança graves.
- Tempo médio entre upload e exportação menor que 30 minutos.

13. Conclusão

O ClinicBridge não tenta ser um prontuário, não tenta ser um sistema de gestão completo e não promete revolucionar o setor. Ele atende uma dor pontual — sair do sistema antigo sem perder dados — com escopo controlado, segurança aplicada desde o desenho e potencial de venda imediato.

A combinação entre um problema claro, um escopo enxuto, uma arquitetura que facilita manutenção e revisão, e uma postura cuidadosa em relação à LGPD reduz o risco operacional e regulatório. Isso permite construir um MVP em poucas semanas e começar a validar a hipótese comercial sem precisar de uma operação grande.

14. Referências e conceitos utilizados (pasta Ciber)

Os conceitos a seguir foram extraídos diretamente dos materiais da pasta "Ciber" e aplicados no desenho do projeto.

- **Modelagem de Ameaças (Software Seguro — Aula 02):** uso de DFD com fronteiras de confiança e STRIDE como roteiro para identificar ameaças por fluxo. Orientou a seção 9 deste relatório.
- **OWASP Top 10 / A06 — Insecure Design (Aula 02):** ideia de que controles precisam aparecer no desenho do sistema, não só no código. Aplicada no fluxo de upload, autenticação e exclusão.
- **CIAA / requisitos de segurança (Aula 02):** transformar propriedades em requisitos testáveis. Aplicada nos requisitos de segurança e nos critérios de aceite.
- **Padrões de Projeto — MVC + DAO (Aula 05):** definição de papéis e benefícios da separação. Aplicada na arquitetura.
- **Java MVC (Aula 04):** referência conceitual sobre como organizar pastas e responsabilidades. Adaptada para Node + Express.
- **Codificação Segura — ASVS e SEI CERT (Aula 07):** validação de entrada, tratamento de erro, sanitização. Aplicada no upload e na exportação.
- **Criptografia simétrica e assimétrica (Aula 08):** base para escolha de criptografia em repouso para arquivos e TLS em trânsito.
- **Resposta a Incidentes — NIST CSF e NIST SP 800-61 (Aulas 02 e 03 de Resposta a Incidentes):** ciclo Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições Aprendidas. Aplicado na seção 8.

Observação: as referências acima são conceituais. Não foram inventadas fontes externas; o conteúdo veio dos materiais da pasta consultada.